Contenido

5. Autenticación Centralizada 2
5.1 Autenticación Centralizada en Windows 2
5.2 Autenticación Centralizada en Linux 2
5.3 Single Sign-On (SSO) 3
5.3.1 Relación entre LDAP, MAP y SSO o Servidor de Identidades 4
5.4 Protocolos de Autenticación 4
1) Protocolos de Autenticación Propiamente Dichos 4
2) Protocolos Basados en el Marco AAA 5
5.5 Comparativa de autenticación centralizada Linux/Windows 6

5. Autenticación Centralizada

La **autenticación centralizada** surge para resolver el problema de la administración de usuarios en múltiples aplicaciones, recursos y ordenadores en red. Permite a los usuarios acceder a múltiples sistemas o recursos con **un único conjunto de credenciales** (usuario y contraseña).

Esto se logra mediante un **sistema centralizado** (como un servidor de autenticación o directorio) que verifica la identidad del usuario y le proporciona acceso a los recursos autorizados.

Ventajas

- **Simplifica la administración** de cuentas y contraseñas.
- **Mejora la seguridad** al aplicar políticas de acceso coherentes.
- **Facilita la auditoría**.
- **Facilita el monitoreo** de la actividad de los usuarios.
- El administrador mantiene una **única base de datos** de usuarios y grupos.

5.1 Autenticación Centralizada en Windows

En el entorno de Windows, se basa en el servicio de directorio **Active Directory (AD)**.

- El servidor AD central registra y gestiona a los usuarios y los recursos de red.
- Cuando un usuario intenta acceder a recursos de red, el servidor AD verifica las credenciales y autentica su identidad.
- Permite aplicar **políticas de seguridad uniformes** y se integra con otras características como la **Administración de Directivas de Grupo (Group Policy)**. Con esta opción, puedes asegurarte de que un conjunto específico de usuarios reciba las reglas que has definido para ellos.

5.2 Autenticación Centralizada en Linux

En entornos Linux, se logra con herramientas y protocolos como **LDAP** (**Lightweight Directory Access Protocol, Protocolo Ligero de Acceso a Directorio**) (por ejemplo, OpenLDAP) y **PAM** (**Pluggable Authentication Modules, Módulos de Autenticación Conectables**).

- Las credenciales se almacenan en un **servidor LDAP centralizado**.

- El sistema Linux envía una solicitud al servidor LDAP para verificar las credenciales.
- **PAM** es un marco de autenticación modular que permite a los administradores configurar políticas de autenticación de forma flexible y centralizada. Se utiliza para controlar el acceso, el método de autenticación y las acciones permitidas.
- Al usar **PAM junto con sistemas de directorios LDAP**, se logra una autenticación centralizada completa.

Ambos son esenciales para la autenticación centralizada en Linux. **LDAP** proporciona el sistema de directorio donde se almacenan las credenciales, y **PAM** es el marco modular que gestiona cómo se utiliza ese directorio (junto con otros métodos) para la autenticación en diversos servicios.

5.3 Single Sign-On (SSO)

El **SSO o Servidor de Identidades** es una solución de autenticación que permite a los usuarios iniciar sesión en **múltiples aplicaciones y sistemas con una sola identificación**.

- Una vez autenticado en un servicio SSO, se concede acceso a otros sistemas vinculados **sin necesidad de reintroducir credenciales**.
- Mejora la comodidad y reduce el riesgo de contraseñas débiles o reutilizadas.
- Habitualmente se utiliza un servidor **LDAP** para lograrlo.
- Un ejemplo es Google, que una vez identificado permite el uso de distintos servicios (correo, calendario, etc.).

Funcionamiento Básico de SSO (Diagrama) 1.

El **Usuario** accede a una **Aplicación web**

2. La aplicación contacta con el **Servidor de identidades (SSO)**.
3. Si el usuario no ha iniciado sesión, la aplicación redirige al navegador al Servidor de identidades.
4. El Servidor de identidades solicita las credenciales.
5. El usuario se autentica.
6. El Servidor de identidades redirige al navegador a la aplicación web, con un **token de usuario**.

7. La aplicación web permite el acceso al usuario cuyos datos están contenidos en el token.

5.3.1 Relación entre LDAP, MAP y SSO o Servidor de Identidades

La secuencia lógica es:

1. **El Usuario** intenta acceder al primer servicio.
2. **El Servicio** pide credenciales.
3. **PAM** (en Linux) o la capa de autenticación de Active Directory (en Windows) intercepta la petición y la envía al **Servidor de Identidades/SSO**.
4. **El Servidor de Identidades/SSO** utiliza **LDAP** para comprobar si el usuario y contraseña son correctos.
5. Si la autenticación en LDAP es exitosa, el servidor SSO emite un **Token o Ticket de Servicio** (como el TGT de Kerberos) que prueba la identidad del usuario.
6. Este **Token** es el que evita que te tengas que autenticar de nuevo con la base de datos LDAP/AD cada vez que accedes a un nuevo servicio, logrando el **Acceso Único (SSO)**.

5.4 Protocolos de Autenticación

Los protocolos de autenticación se dividen en dos categorías principales:

1) Protocolos de Autenticación Propiamente Dichos

Protocolos utilizados por otros protocolos superiores para llevar a cabo la fase de autenticación. Dicha fase puede incluir el envío de datos de sesión, contraseñas de un solo uso, hash MD5 (función criptográfica, que genera un hash o clave secreta encriptada), certificado digital (es un archivo electrónico emitido por una Autoridad de Certificación que vincula una clave pública a una identidad (usuario, servidor o dispositivo)), etc.

- **CHAP** y **MD5 Challenge-Response** son ejemplos que pueden emplear MD5.
    - CHAP: Protocolo de autenticación completo que sirve para autenticar al usuario de forma segura sin enviar la contraseña en texto claro.
    - MD5 Challenge-Response: Mecanismo criptográfico (un proceso específico dentro de un protocolo). Producir una huella digital (hash) irreversible y única para proteger la contraseña.

- **EAP (Extensible Authentication Protocol)**: No es propiamente un protocolo de autenticación, sino un **sistema para transportar métodos de autentificación** por la red. Permite usar múltiples métodos (contraseñas, certificados, biometría) y se usa en WPA/WPA2 en Wi-Fi y en VPNs.
- **KERBEROS**:
    - Protocolo de autenticación de red basado en un modelo de **desafío y respuesta**.
    - Utiliza un **Ticket** de autenticación (TGT) emitido por un servidor de autenticación (**KDC** - Key Distribution Center).
    - Este Ticket se usa para autenticar al usuario en otros servicios sin introducir credenciales de nuevo (**SSO**).
    - Se usa en Windows (**Active Directory**), Unix y Linux.

Funcionamiento Básico de Kerberos 1.

El **Usuario** solicita un **TGT** (Ticket-Granting Ticket o Ticket de autenticación) al KDC (**AS** - Authentication Server):

2. El KDC envía el TGT cifrado.
3. El Usuario presenta el TGT (descifrado, gracias a su hash o clave cifrada, que solo él y el KDC conocen) al KDC y solicita un **Ticket de Servicio (ST o TGS** - Ticket-Granting Service**)** para un recurso.
4. El KDC envía el Ticket de Servicio.
5. El Usuario presenta el ST al **Servidor de Recursos** (Servidor 1) para ser autenticado y obtener acceso.

Conclusión:

La relación entre Single Sign-On (SSO) y Kerberos es**:**

- **Single Sign-On (SSO)** es el concepto o la meta: "Usar un solo inicio de sesión para múltiples recursos."
- **Kerberos** es el protocolo técnico que logra esa meta.

---

2) Protocolos Basados en el Marco AAA

Se centran en la **A**utenticación (“¿quién eres?”), **A**utorización (“¿qué puedes hacer?”) y **A**ccontabilidad (Contabilidad, “te observo, ¿qué has hecho?”). Internamente, usan protocolos de la primera categoría para la fase de autenticación.

- **RADIUS (Remote Authentication Dial-In User Service)**: Estándar de autenticación y autorización para el **control de acceso de usuarios que se conectan de forma remota**. Funciona mediante comunicación entre un cliente de acceso remoto y un servidor RADIUS centralizado.
- **TACACS+ (Terminal Access Controller Access-Control System Plus)**: Se utiliza principalmente en **dispositivos de red** (routers y switches), ofreciendo mayor seguridad (usa protocolo TCP en vez de el UDP que se usa en Radius) flexibilidad (permite distintos niveles de acceso) y control que RADIUS.
- **DIAMETER**: Evolución de RADIUS que proporciona mayor capacidad de AAA, usado en redes de próxima generación (móviles, VoIP).

5.5 Comparativa de autenticación centralizada Linux/Windows

Característica	**Linux/Unix (PAM + LDAP)**	**Windows (Active Directory + Kerberos)**
Filosofía	**Modularidad y Separación de Tareas**	**Integración Profunda**
Estructura	Un **marco de trabajo** (PAM) usa un **protocolo** (LDAP) o Kerberos (via un módulo) para verificar una **identidad**.	Un **servicio de directorio** (AD) que tiene **Kerberos** como protocolo de autenticación **integrado** en el núcleo.
Flexibilidad	Alta. Puedes cambiar el método de autenticación sin tocar la aplicación.	Baja en comparación. El método de autenticación es intrínseco a Active Directory. Cada aplicación tiene que tener en cuenta el método de autenticación.
Aplicación	La aplicación habla con **PAM**.	La aplicación habla con el **sistema operativo**, que

Característica	Linux/Unix (PAM + LDAP)	Windows (Active Directory + Kerberos)
		delega la autenticación a Kerberos/AD.

Por tanto, Linux apuesta por la separación de Autenticación y Aplicación: Las aplicaciones (login, su, vsftpd) no necesitan saber *cómo* se autentica el usuario. Solo necesitan pedir: "Oye, PAM, ¿este usuario es válido?". Este modularidad simplifica tanto el desarrollo de aplicaciones como la gestión del sistema.

En Windows, la autenticación está intrínsecamente ligada al dominio AD y a su protocolo nativo (Kerberos), lo que simplifica la administración a costa de una menor flexibilidad de "enchufar" otros métodos.
